Práctica 07 — Parchear y demostrar la mitigación

Semana 7 — Fase 3: Defensa y hardening

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Duración	3 horas de laboratorio
Modalidad	4 grupos con roles rotativos
Entrega	Repositorio GitHub del grupo, carpeta semana_07, antes del corte semanal
Instrumento	control fase 3

1 Objetivo

Corregir vulnerabilidades en código y demostrar la mitigación repitiendo el mismo payload, con controles automatizados en la cadena de suministro.

2 Contenidos que se aplican

- Validación de entrada y salida, parametrización de consultas.
- Codificación de salida, CSP y cabeceras de seguridad.
- Gestión de dependencias, SBOM y pip-audit.
- Análisis estático con bandit y escaneo de secretos.
- Revisión de código y criterios de aceptación de seguridad.

3 Escenario

Cada grupo corrige tres vulnerabilidades de la semana 5 en su copia del laboratorio y demuestra que el payload original ya no funciona.

4 Procedimiento

1. Reproducir los tres hallazgos sobre la copia sin parchear y guardar la evidencia.
2. Aplicar la corrección con parametrización, codificación de salida y validación.
3. Repetir exactamente el mismo payload y documentar el nuevo resultado.
4. Ejecutar bandit, pip-audit y escaneo de secretos, y adjuntar la salida.
5. Escribir el criterio de aceptación de seguridad que impediría la regresión.

5 Entregable

Parches, evidencia antes y después con el mismo payload, y salida de los tres controles.

6 Rúbrica de corrección

Criterio	Peso
Correcciones que eliminan la causa raíz, no el síntoma	3,0
Demostración antes y después con el mismo payload	2,5
Controles automatizados ejecutados e interpretados	2,0
Criterio de aceptación que previene la regresión	1,5
Sin regresiones funcionales en la aplicación	1,0
Total	**10,0**

Antes de empezar: confirma que el objetivo es un contenedor del laboratorio o un sistema con autorización escrita. Si no lo es, detente y consulta al docente: la práctica no se corrige sin ese requisito.